한국융합보안학회 2024년 추계학술대회 논문집

머신러닝을 활용한 피싱 탐지 · 차단 시스템 연구: PDCA 방법론을 기반으로

정진호[1], 박우경[1], 이하영[1], 최수민[1*], 홍준희[1], 김민수[2]
중부대학교 정보보호학전공 학부생[1], 중부대학교 정보보호학전공 교수[2]

Research on phishing detection and blocking system using machine learning: Based on PDCA methodology

Jin-Ho Jung[1], Woo-Kyung Park[1], Ha-Young Lee[1], Su-Min Choi[1*], Jun-Hee Hong[1], Min-Su Kim[2]

요약 : 디지털 정보화 시대에 사이버 활동이 일상화되면서 개인정보 노출로 인한 사이버 보안 문제가 꾸준히 증가하고 있다. 특히 다수의 사용자가 이용하는 서비스를 사칭해 개인정보를 노리는 피싱 공격과 링크 클릭을 유도해 악성 파일을 설치하려는 스미싱 공격 등을 통해 매년 공격 방식이 진화하고 피해 사례가 급증하고 있다. 본 연구에서는 머신러닝을 활용해 피싱 탐지 및 차단 시스템 구축에 도움을 제공하며, 사이버 위협에 신속하고 능동적으로 대처하는 방법을 제공할 것으로 기대한다.

Key Words : Malicious URL, Malware, Machine Learning, XGBoost, Phishing

1. 서 론

오늘날 디지털 정보화 시대에 대부분의 사람은 SNS(Social Network Service)나 전자금융 거래 서비스 등과 같은 사이버 활동을 일상적으로 하고 있다. 이처럼 인터넷 환경이 실생활과 밀접해지면서 개인정보 노출로 인한 사이버 보안 문제는 매년 꾸준히 증가하고 있다[1].

특히 포털이나 메신저 등 다수의 사용자가 이용하는 서비스를 정교하게 사칭해 개인정보를 노리는 피싱(Phishing) 공격이 점차 진화하고 있으며, 링크 클릭을 유도해 악성 파일을 설치하려는 스미싱 공격도 계속해서 확산하고 있다. 과학기술정보통신부 2023년 기준으로 피싱과 스미싱 같은 사이버 보안 문제로 인해 약 37만 건 이상의 개인정보 유출 및 금전적 피해 사례가 탐지되었고, 문자나 메신저 채팅을 통해 피싱 URL 악용한 해커들의 공격은 끊임없이 이어지고 있다[1].

따라서 본 연구는 피싱, 스미싱과 같은 사이버 보안 문제의 심각성을 해결하기 위해, 머신러닝을 활용한 피싱 탐지 및 차단 방법을 제안하고자 한다.

2. 관련 연구

2.1. PDCA 방법론

과정	주요 수행 내용
Plan	연구 활동 계획 수립 단계
Do	수립한 계획의 실험 단계
Check	실험 결과에 대한 검증 단계
Action	제안 및 재검토 단계

Table. 1. A step-by-step PDCA

PDCA 방법론이란 Plan, Do, Check, Action의 순환형 단계로 설정한 목표에 대한 개선 및 검증 단계를 거듭하여 최종 결과의 향상 시키는 제안 방안이다[2].

본 연구에서는 정상 사이트와 피싱 사이트 간의 명확한 차이점을 갖는 칼럼 선정 단계에 대한 가이드라인을 제시하고자 한다.

2.2. 시그니처 기반의 피싱 URL 탐지

피싱, 스미싱 공격 등과 같은 사이버 보안 문제를 해결하기 위해 다양한 탐지 및 차단 방법이 존재하는데, 그 중 리스트 기반의 연구가 지속 되었다. 이 방식은 악성 URL을 블랙 리스트나 화이트 리스트에 미리 지정하여, 이에 해당하는 도메인에 대해서만 차단하는 탐지 방법의 하나이다.

하지만, 이 방식은 신·변종 악성 URL에 대한 대응이 어렵고, 수동적인 업데이트가 지속적으로 이루어져야 한다는 단점이 존재해 탐지 및 차단 정확도가 저하된다[3].

2.3. 규칙 기반의 피싱 URL 탐지

시그니처 기반의 탐지 방식과 달리 규칙 기반의 탐지 방식은 사용자가 피싱 사이트의 접속으로 인해 발생한 공격자의 공격 시도 과정 안에 일정한 알고리즘을 찾아내고, 이에 해당하는 패턴이 보이면 차단하는 방법의 하나이다. 기존 공격자의 패턴에 대해서는 피싱 시도 여부를 알 수 있지만, 규칙과 다른 공격이 발생했을 경우 탐지하지 못하는 단점이 존재한다[3].

이 한계점을 해결하기 위해 능동적이고 신속하게 판단할 수 있는 머신러닝을 활용한 피싱 URL 탐지 방법을 제안한다.

2.4. 학습 알고리즘

정상 사이트와 피싱 사이트 간의 뚜렷한 차이점이 존재한 칼럼의 수가 많을수록 악성 URL 탐지율이 높아진다. 칼럼에 부합하는 수집된 데이터는 전처리 과정을 거치고, 높은 차단률과 낮은 오탐률을 제공하기 위해 적합한 알고리즘을 선택하는 과정이 중요하다.

다양한 기법 중 XGBoost 알고리즘은 데이터셋을 유연하게 활용할 수 있고, 반복적인 오차 학습을 통해 최종 예측 모델의 정확도를 높일 수 있다. 이 학습 알고리즘은 URL의 도메인 정보, 리다이렉트 경로 등과 같은 큰 데이터셋에서 높은 정확도를 보여준다[4].

3. 제안하는 방법론

본 연구는 효과적인 피싱 사이트 탐지 · 차단 과정을 통해 지속적인 사이버 보안 문제의 피해를 줄이기 위한 전체적인 PDCA 방법론을 채택하였다.

3.1. Plan (계획)

Plan 단계에서는 수동적으로 이루어지는 피싱 사이트 차단 방식을 개선하기 위해, 능동적인 탐지가 가능한 머신러닝 알고리즘을 도입함으로써 피싱 사이트의 차단률 향상을 목표로 한다. 높은 차단률을 제공하기 위한 반복적 오차 학습에 유리한 XGBoost 머신러닝을 선택했다.

3.2. Do (실행)

Do 단계에서는 피싱 탐지를 위한 XGBoost 머신러닝 학습에 20,171개의 정상 사이트와 피싱 사이트의 데이터셋을 이용하고, 37가지의 칼럼을 선정해 피싱 탐지 및 차단률의 성능을 개선하는 방법을 제안한다.

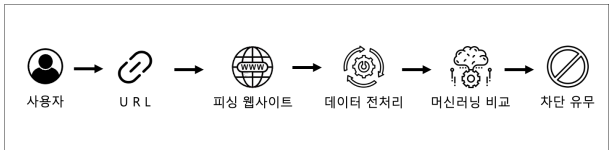

Fig. 1. Phishing Site Detection and Blocking System Course

머신러닝 학습 과정에는 차이점이 명확한 칼럼 선정이 필요하다. 피싱 사이트와 정상 사이트 간의 차이가 확연할수록 학습 알고리즘의 정확도가 향상된다.

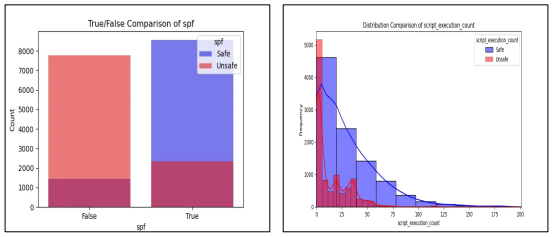

Fig. 2. SPF column analysis graph / Script execution count column analysis graph

본 연구에서는 '스크립트 실행 횟수, 이메일 스푸핑 공격 방지 기능(SPF), 텍스트/이미지 비율 등' 두 라벨 간의 차이가 뚜렷한 37가지의 칼럼을 선정하여 모델 학습에 사용했다. Fig. 2.의 오른쪽 그래프와 같이 피싱 사이트는 정상 사이트에 비해 스크립트 실행 횟수가 현저히 적었으며, 왼쪽 그래프에서는 SPF 여부가 주로 정상 사이트에 나타나는 기능임을 확인했다.

3.3. Check (검증)

Check 단계에서는 차단률 향상의 목표를 위해 Do 단계에서 선정한 칼럼을 바탕으로 머신러닝을 생성하여 결과를 확인한다. XGBoost 알고리즘을 이용해 37개의 칼럼으로 머신러닝을 학습한 결과, 97.2%의 정확도를 보였다.

학습 알고리즘	차단률
HD	89.1%
ET	95.6%
DT	96.1%
GB	96.9%
RF	97.2%
XGB	**98.1%**

Table. 2. Phishing detection rate with XGBoost

학습에 이용하지 않은 피싱 사이트 20,417개를 제작한 XGBoost 머신러닝으로 비교한 결과, 98.1%의 차단률을 확인했다. 다른 학습 알고리즘을 통해 결과를 조사한 바로는, 대부분 95% 대의 차단률을 보여주고 있다[5][6].

3.4. Action (개선)

마지막으로 Action 단계에서는 앞 과정에서 진행한 Plan, Do, Check의 과정을 도합하여 문제점을 지속적으로 개선해 나가면서 최종 결과를 도출한다.

데이터셋을 보고 학습에 유리한 머신러닝 기법을 선정하고, 지도 학습에 영향을 주는 칼럼을 선정하여 단계별로 정확도를 높여간다. 검증 과정 이후, 목표를 만족할 때까지 4단계의 과정을 반복 수행한다.

본 연구에서는 피싱 사이트를 능동적으로 차단하며, 높은 차단률을 제공하는 Plan에 부합하도록, 지속적인 칼럼 연구를 통해 능동적인 피싱 사이트 탐지 방법론을 제안한다.

4. 결론

기존의 수동적 탐지 방식인 스테틱 과정의 한계를 개선하고, 향상된 탐지 방법을 제공하기 위해 여러 머신러닝 알고리즘 중 XGBoost를 활용한 피싱 사이트 탐지 및 차단 시스템을 제안한다. 또한, 정상 사이트와 피싱 사이트 간의 차이점이 있는 칼럼을 선정함으로써, 두 라벨 간의 구별된 피쳐가 차단률에 큰 영향을 미치는 것을 확인했고, 최종 98.1% 차단률을 보였다.

본 연구와 같이 피싱 사이트 탐지 및 차단을 효율적으로 수행하기 위해 PDCA 방법론을 기반으로 머신러닝 알고리즘을 선택하고, 차이점이 명확하게 구별되는 칼럼을 선정하여 최종 목표에 도달할 수 있는 PDCA 방법론을 제안한다.

참고문헌

[1] S.Y.Kim, “Cybersecurity Threat Analysis for 2023 and Predictions for 2024”, Ministry of Science and ICT, Dev. 18, 2023, https://www.msit.go.kr/bbs/view.do;jsessionid=dIGGQaXtoSBmMIqR9gQcLhH1mWDCf6CGmjMGm-94.AP_msit_1?sCode=user&mPid=238&mId=113&bbsSeqNo=94&nttSeqNo=3183831

[2] J.H.Lee ‘A Study on the Application of Blockchain Technology to Improve Industrial Safety: Focusing on PDCA Mode’, Inha Univ, Aug. 2023.

[3] J.K.Kim, M.H.Jang, S.N.Lim, M.S.Kim, “A Study on the Detection Method of Malicious URLs based on the Internet Search Engines using the Machine Learning”, The Transactions of the Korean Institute of Electrical Engineers, Vol. 70, No. 1, pp. 114-120, 2021.

[4] J.H.Lee, Y.T.Shin, “CV-based malicious URL detection ensemble stacking model”, KIPS, Vol. 31, No. 1, pp. 846-849, May. 23, 2024.

[5] Y.J.Kim, J.W.Lee, “Development of a Malicious URL Machine Learning Detection Model Reflecting the Main Feature of URLs”, Journal of the Korea Institute of Information and Communication Engineering, Vol. 26, No. 12, pp. 1786-1793, Dec. 2022.

[6] C.R.Han, S.H.Yun, M.J.Han, I.G.Lee, “Machine Learning-Based Malicious URL Detection Technique”, Journal of The Korea Institute of Information Security & Cryptology, Vol. 32, No. 3, pp. 555-564, Jun. 2022.